Executive Summary

1. Purpose

To assess information security and service risks arising from the deployment of a new Electronic Health Record (EHR) platform, and to define the governance, controls and reporting needed to keep the service secure, available and auditable.

2. Scope

EHR application and database, backup and disaster recovery environment, integrations with laboratory and insurance systems, vendor-hosted integration layer, identity and access management, and clinical endpoints (workstations and mobile devices). Data in scope: Protected Health Information (PHI) and billing data.

3. Methodology

Risks were identified through a framework gap assessment (COBIT maturity, ISO 27001 scoping, ITIL process review) and scored on a 5x5 likelihood and impact matrix. Scores of 15 or above require urgent treatment. Each risk has a named owner and is mapped to a COBIT objective, an ISO 27001 control area and an ITIL process. Treatment decisions follow the standard options: mitigate, transfer, avoid or accept.

4. Key Findings

Twelve risks were registered. Four scored 15 or above; the remaining eight scored between 8 and 12.

Risk	Score	Owner	Primary Treatment	Target Residual
Ransomware on EHR	20	CISO	EDR, immutable backups, network segmentation	2
Legacy interface vulnerability	16	Integration Lead	Replace or isolate; penetration test; WAF	3
Insider data misuse	15	Head of HR	Role-based access, monitoring, DLP	2
Third-party vendor breach	15	Vendor Manager	Security assurance, contract clauses, credential segregation	2

Patient safety is the dominant impact driver: three of the four priority risks could interrupt or compromise clinical systems.

5. Governance and Controls

Oversight is assigned to a Security and Risk Committee (residual risk and major incidents) and a Change Advisory Board (changes to the EHR), with a RACI covering policy approval, change approval and incident response. The CMIO accepts clinical risk decisions. Operational control is provided by ITIL-based Incident, Change and Problem Management procedures.

6. Monitoring and Targets

Monthly reporting covers open risks and percentage mitigated, P1 incident detection and resolution times, change success rate, vendor assessment coverage, patch compliance, backup restore success and policy exceptions. Service target: EHR availability of 99.95%. Control targets: ransomware detection within 30 minutes; restoration from immutable backup within 4 hours.

7. Decisions Requested

1. Approve the risk treatment plan and the residual risk targets above.
2. Prioritize funding for EDR with immutable backups and for legacy interface replacement.
3. Approve the ISO 27001 certification budget, if certification is pursued.
4. Allocate training time for clinical staff.

8. Next Steps

Complete high-priority treatments by target dates; run a ransomware tabletop exercise and a backup restore test; conduct an internal audit against ISO 27001 and COBIT objectives; present the first monthly risk report to the Security and Risk Committee.